

Security and Access Document

Swasthya Katha — Privacy-Preserving Health Education

Version: 1.0

Status: Draft for security and legal review

Date: 24 August 2026

1. Purpose

This document defines how the system protects readers, staff, content, assets, publication workflows, and optional user accounts.

The subject matter is sensitive. The security strategy therefore starts by avoiding unnecessary collection rather than trying to protect large amounts of data that the product does not need.

2. Security objectives

- Allow private reading without an account.
- Prevent exposure of sensitive usage data.
- Protect unpublished medical content.
- Enforce reviewer separation.
- Prevent unauthorized publication.
- Protect staff credentials.
- Sanitize all uploaded assets.
- Make changes auditable and reversible.
- Provide safe, non-revealing errors.
- Recover quickly from content or technical incidents.

3. Security principles

1. Deny by default.
2. Least privilege.
3. Anonymous by default.
4. Server-side authorization.
5. Separate public and draft assets.
6. Human approval for clinical publication.
7. Immutable release versions.
8. Minimize logs and analytics.

9. Sanitize untrusted content.
10. Test negative permissions, not only positive permissions.

4. User roles

Anonymous reader

Can:

- Read published public content.
- Use approved audio and visuals.
- Change language.
- Store local bookmarks.

Cannot:

- Access drafts.
- Submit medical content.
- Access staff tools.
- View another user's data.

Learner account

Can:

- Synchronize explicitly consented progress.
- View and delete own progress.
- Manage own account.

Cannot:

- View other users.
- Access internal content.

Editor

Can:

- Create and edit drafts.
- Upload proposed assets.
- Submit content for review.

Cannot:

- Approve own clinical content.
- Publish without required approvals.

Clinical reviewer

Can:

- Review medical claims.
- Add sources.
- Approve or reject clinical status.

Cannot:

- Change access policies.
- Access unnecessary learner information.

Language reviewer

Can:

- Review translations.
- Approve narration scripts.

Cannot:

- Change approved clinical meaning silently.

Accessibility reviewer

Can:

- Review alternatives, captions, focus, contrast, and motion.
- Block release for critical accessibility defects.

Administrator

Can:

- Manage publication workflows.
- Manage roles.
- Roll back releases.
- View audit records.

All privileged operations require auditing.

5. Permissions matrix

Action	Anonymous	Learner	Editor	Clinical	Language	Accessibility	Admin
Read published content	Yes	Yes	Yes	Yes	Yes	Yes	Yes

Action	Anonymous	Learner	Editor	Clinical	Language	Accessibility	Admin
Read draft	No	No	Assigned	Assigned	Assigned	Assigned	Controlled
Create draft	No	No	Yes	Optional	No	No	Yes
Approve clinical	No	No	No	Yes	No	No	Controlled
Approve language	No	No	No	No	Yes	No	Controlled
Approve accessibility	No	No	No	No	No	Yes	Controlled
Publish	No	No	No	No	No	No	Controlled
Read own progress	No	Yes	No	No	No	No	Minimal/audited
Delete own account	No	Yes	Staff process	Staff process	Staff process	Staff process	Controlled

6. Authentication

Public access

No login is required for reading.

Staff access

- MFA mandatory.
- Strong identity provider or passkey preferred.
- Short-lived sessions.
- Refresh-token rotation.
- Re-authentication for publication and role changes.
- Session revocation after role removal.

Learner access

Optional and delayed until the value is proven. If introduced:

- Clear consent.
- Minimal profile.
- Account deletion.
- No health history fields by default.

7. Authorization model

Every protected mutation must verify:

1. Identity.
2. Role.
3. Resource assignment.
4. Workflow state.
5. Required approvals.
6. Audit event.

Client-side role hiding is not authorization.

8. Row-level security

Policy goals:

- Anonymous users select only published records.
- Editors access assigned drafts.
- Reviewers access assigned review objects.
- Learners access only their own progress.
- Admin queries require explicit server-side role checks.
- Storage access mirrors database access.

Illustrative intent:

```
create policy "public reads published lessons"
on lessons for select
to anon, authenticated
using (status = 'published');

create policy "learner owns progress"
on user_progress for all
to authenticated
using (user_id = auth.uid())
with check (user_id = auth.uid());
```

Final SQL must be tested against the exact schema, roles, and service-account behaviour.

9. Data classification

Public

- Published lesson content.
- Approved public assets.
- Public help text.

Internal

- Drafts.
- Review notes.
- Source records.
- Publication workflow metadata.
- Audit events.

Sensitive

- Staff identity and permissions.
- Optional learner identity.
- Optional synchronized progress.
- Support or incident records.

Do not collect health status, diagnosis, sexual history, or free-form sensitive questions for the basic product.

10. Threat model

Malicious content injection

Controls:

- Plain text by default.
- Sanitized rich text.
- Strict URL allowlist.
- Content Security Policy.
- No arbitrary scripts.

Unsafe SVG

Controls:

- Parse and sanitize on upload.
- Remove scripts and event handlers.
- Remove external resource references.
- Validate again at publication.
- Serve through controlled asset paths.

Draft exposure

Controls:

- Server-side status filtering.
- RLS.
- Separate storage paths.
- Anonymous negative tests.

Privilege escalation

Controls:

- Central policy functions.
- Role and scope checks.
- Audit events.
- Permission regression tests.

Account takeover

Controls:

- MFA.
- Rate limiting.
- Secure session management.
- Credential rotation.
- Login monitoring.

Sensitive analytics

Controls:

- Do not send health-topic identity associations.
- Avoid sensitive URL parameters.
- Minimize event retention.
- Document every collected field.

Malicious file upload

Controls:

- Size limits.
- MIME validation.
- File signature validation.

- Malware scanning where available.
- SVG sanitization.
- Human review before publication.

11. Secure error handling

User-facing messages:

- “This lesson is temporarily unavailable.”
- “Audio is unavailable. You can read the transcript.”
- “This visual is unavailable. Open the text explanation.”

Never return:

- Stack traces.
- SQL details.
- Internal file paths.
- Tokens.
- Reviewer notes.
- Draft content.

12. Privacy controls

- Anonymous reading.
- Clear local-state button.
- Privacy notice in simple language.
- Optional analytics consent where required.
- No sensitive browser notification content.
- No precise location by default.
- Data retention schedule.
- User deletion process.

13. Audit events

Record privileged events:

```
content_created
content_updated
review_submitted
review_approved
review_rejected
publication_created
publication_published
publication_rolled_back
role_changed
```



```
asset_sanitized
asset_rejected
account_deleted
```

Audit records must not contain unnecessary medical content or secrets.

14. Security testing

Automated

- RLS tests.
- Route authorization tests.
- Input validation tests.
- SVG sanitization tests.
- Secret scanning.
- Dependency scanning.
- Security-header tests.

Manual

- Role boundary review.
- Draft-exposure test.
- Session revocation test.
- Admin workflow test.
- File-upload abuse test.
- Error-message review.

15. Incident response

Content safety incident

1. Disable affected content.
2. Notify clinical owner.
3. Preserve version and evidence.
4. Assess exposure.
5. Correct and re-review.
6. Publish corrected version.
7. Record root cause.

Privacy/security incident

1. Contain the issue.
2. Revoke credentials or URLs.
3. Preserve evidence.
4. Determine affected data.
5. Follow applicable notification requirements.
6. Patch and test.
7. Document corrective action.

Outage

1. Confirm scope.
2. Enable static or cached fallback.
3. Roll back or restore.
4. Run smoke tests.
5. Monitor recovery.

16. Security acceptance criteria

- Anonymous users cannot access drafts.
- Learners cannot read another learner's progress.
- Editors cannot approve their own clinical content.
- Reviewers cannot publish without required approvals.
- Unsafe SVG is rejected.
- Secrets are not committed.
- P0 errors reveal no sensitive detail.
- MFA is enabled for privileged staff.
- Rollback is tested.
- Incident owner is assigned.